

Develop and Apply Risk Management Strategies

Final Report — Risk Identification, Treatment, and Monitoring

Derived from the Apply Vulnerability Assessment Techniques scan results (scanme.nmap.org)

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Develop and Apply Risk Management Strategies
Risk Source	Apply Vulnerability Assessment Techniques — Final Report (149 unique CVEs, scanme.nmap.org)
Document Version	1.0
Prepared By	Sabitha S Karanavar
Report Date	September 8, 2026

1. Rubric Cross-Reference

This report satisfies both required components of the “Develop and Apply Risk Management Strategies” rubric line.

Rubric Requirement	Section	Evidence
2 critical risks identified, explained, with treatment and mitigation	Section 2	Risks derived from the 27 Critical (CVSS 9.0–10.0) findings in the vulnerability scan
1 risk monitoring procedure	Section 3	Recurring scan cadence + risk register + escalation thresholds

2. Risk Identification from Vulnerability Scan Results

Risks below are drawn directly from the Apply Vulnerability Assessment Techniques report, which classified 149 unique CVEs found against scanme.nmap.org, including 27 rated Critical (CVSS 9.0–10.0). The two highest-value risks — one per exposed service — are detailed here, since each represents a distinct root cause requiring separate treatment.

2.1 Critical Risk 1 — OpenSSH 6.6.1p1 Remote Code Execution (CVE-2023-38408, CVSS 9.8)

Explanation	OpenSSH 6.6.1p1 (Ubuntu, dated 2014) is vulnerable to a remote code execution flaw in ssh-agent forwarding: a malicious or compromised SSH server can abuse a forwarded agent to load an attacker-specified PKCS#11 provider, achieving code execution on the client. Because the flaw lives in agent forwarding rather than authentication, it can be triggered without the attacker holding valid credentials.
Likelihood	Medium — requires the target to have agent forwarding enabled and to connect to (or be tricked into connecting to) an attacker-controlled or compromised host. Not remotely triggerable against a passive listener with no other precondition.
Impact	Critical — successful exploitation yields arbitrary code execution on the client, i.e. full compromise of whichever machine initiated the forwarded connection.
Treatment	Mitigate: upgrade OpenSSH to a supported, patched release. A decade-old point release accumulates every subsequent CVE, not just this one, so a version upgrade addresses far more than this single finding.
Mitigation Steps	(1) Patch/upgrade OpenSSH to current stable; (2) disable ssh-agent forwarding (-A) by default and enable it only per-session when explicitly required; (3) restrict which hosts are permitted to receive forwarded agents

	via ssh_config Host blocks; (4) monitor authentication logs for unexpected PKCS#11 provider load attempts.
--	--

2.2 Critical Risk 2 — Apache HTTP Server 2.4.7 mod_lua Buffer Overflow (CVE-2021-44790, CVSS 9.8)

Explanation	Apache httpd 2.4.7 (Ubuntu, dated 2014) is exposed to a buffer overflow in mod_lua's multipart request body parser. A crafted multipart POST request can overflow a buffer on the server, and depending on server configuration this can be leveraged for remote code execution or a crash (denial of service).
Likelihood	Medium-High — the vulnerability requires mod_lua to be enabled with a script handling multipart parsing, but the vulners lookup flagged public exploit code as available for a large share of this host's Apache CVEs, which meaningfully raises real-world likelihood versus a theoretical-only finding.
Impact	Critical — potential remote code execution on the web server, or at minimum a reliable denial-of-service condition against a public-facing service.
Treatment	Mitigate: upgrade Apache to a currently supported version. As with OpenSSH, this single decade-old version carries dozens of stacked CVEs (27 Critical findings total across both services), so the fix is a version upgrade, not a per-CVE patch.
Mitigation Steps	(1) Upgrade Apache httpd to a supported release; (2) disable mod_lua if the application does not require it, reducing attack surface directly; (3) place a WAF or reverse proxy in front of the service as a compensating control while the upgrade is scheduled; (4) restrict direct exposure of the service to only the network segments that require it.

2.3 Risk Register Summary

Risk	CVSS	Likelihood	Impact	Rating	Treatment
OpenSSH agent-forwarding RCE (CVE-2023-38408)	9.8	Medium	Critical	Critical	Mitigate — upgrade + policy control
Apache mod_lua buffer overflow (CVE-2021-44790)	9.8	Medium-High	Critical	Critical	Mitigate — upgrade + WAF + reduce surface

Justification: both risks were rated Critical overall despite differing likelihoods because impact is the binding constraint at CVSS 9.8 — a Medium-likelihood path to full compromise still warrants Critical treatment under standard risk-matrix conventions (Impact × Likelihood, with Critical impact flooring the overall rating regardless of a Medium likelihood score).

3. Risk Monitoring Procedure

A lightweight, repeatable procedure to track these and future risks over time, rather than treating the vulnerability scan as a one-time snapshot:

- Recurring scan cadence: re-run `nmap -sV --script vuln` against in-scope hosts on a fixed schedule (recommended: monthly, or immediately after any service version change) to catch newly disclosed CVEs against unchanged software.
- Risk register: maintain a tracking log (spreadsheet or ticketing system) with columns for Risk ID, CVE(s), date identified, CVSS score, likelihood/impact/rating, treatment decision, remediation owner, target date, and last-reviewed date.
- Escalation threshold: any newly identified Critical (CVSS ≥ 9.0) finding triggers a review within 24 hours and an update to the register's status field; High findings are reviewed within one week.
- Trend tracking: compare each scan's open-finding count and severity mix against the prior scan to see whether exposure is trending up or down over time, not just what exists right now.
- Closure verification: after a treatment is applied (e.g., a version upgrade), re-scan the specific host/service to confirm the finding no longer appears before marking the register entry closed.

4. Conclusion

Both components of the Develop and Apply Risk Management Strategies rubric are satisfied: two Critical risks were identified directly from vulnerability scan results with full explanation, likelihood/impact reasoning, treatment recommendations, and mitigation steps (Section 2); and a concrete, repeatable risk monitoring procedure was defined to track these and future findings over time (Section 3).

5. References / Sources

- Apply Vulnerability Assessment Techniques — Final Report (this project), source of the underlying scan data and CVSS classification.
- NIST National Vulnerability Database (nvd.nist.gov) — CVE-2023-38408, CVE-2021-44790.
- Vulners.com CVE/exploit correlation database, via the Nmap vulners NSE script.

Prepared for: Sabitha — Healthcare IAM Operations Home Lab | Cyber Threats and Vulnerabilities rubric — Develop and Apply Risk Management Strategies (final report)